



中国科学院大学

University of Chinese Academy of Sciences

研究生学位论文开题报告

报告题目面向复杂任务智能体授权协议研究与实现

删除[风雨中行走]: 双重约束的

学生姓名袁伟奇学号 202428015070007

指导教师徐静职称研究员

学位类别工学硕士

学科专业网络空间安全

研究方向安全协议

培养单位中国科学院软件研究所

填表日期2026 年 06 月

中国科学院大学制

目录

一 选题的背景及意义3

 1.1 授权协议发展脉络 3

 1.2 智能体的广泛应用 4

 1.3 智能体广泛应用的安全挑战 5

 1.4 智能体安全问题 8

 1.5 智能体的授权问题 9

二 国内外本学科领域的发展现状与趋势 11

 2.1 授权领域发展现状与趋势11

 2.1 智能体授权发展现状与趋势 12

三 课题主要研究内容、预期目标 16

 3.1 研究内容 16

 3.2 预期目标 17

四 拟采用的研究方法、技术路线、实验方案及其可行性分析18

五 已有科研基础与所需的科研条件 18

六 研究工作计划与进度安排19

七 参考文献20

一 选题的背景及意义

1.1 授权协议

授权协议是计算机安全体系中用于解决谁在什么条件下可以访问什么资源这一核心问题的关键机制，其发展历程反映了计算机系统从封闭到开放、从单体到分布式的演进趋势。

计算机系统的访问控制最初源于操作系统的文件权限管理。1965 年，Multics 操作系统首次在其文件系统中实现了访问控制列表，为每个文件对象维护一张主体权限映射表，标志着操作系统层面访问控制机制的诞生^[1]。与 ACL 的实践导向不同，1966 年 Dennis 与 Van Horn 在 Multics 系统设计中引入了基于能力的访问控制机制，主张主体持有不可伪造的权限令牌来访问客体，形成了与 ACL 以客体为中心相对立的以主体为中心范式^[2]。1971 年，Lampson 在普林斯顿大学首次提出了访问控制矩阵的形式化模型^[3]。该模型以主体为行、客体为列，通过矩阵单元格定义访问权限，奠定了现代访问控制理论的形式化基础。

早期操作系统访问控制以自主访问控制为主，允许资源所有者自主决定其他主体的访问权限，ACL 即 DAC 的典型实现。然而，DAC 无法防止权限的非法传递与信息泄露。1973 年，Bell 和 LaPadula 为美国国防部开发了 BLP 机密性模型，提出了不上读、不下写的安全原则，成为多级安全系统最早的形式化模型^[4]。BLP 属于强制访问控制，由系统中央权威强制实施安全策略，资源所有者无权修改访问规则。1977 年，Biba 模型提出完整性保护机制，与 BLP 模型形成机密性与完整性互补的 MAC 双支柱^[5]。

随着局域网与分布式计算环境的发展，访问控制从单机走向网络。1988 年，MIT 的 Project Athena 团队发布了 Kerberos 认证协议，Steiner、Neuman 与 Schiller 在 USENIX 会议上首次系统阐述了该协议的设计思想^[6]。1993 年，Kohl 与 Neuman 将 Kerberos V5 标准化为 RFC 1510^[7]，该规范后由 RFC 4120 于 2005 年更新^[8]，成为企业内网分布式身份认证的事实标准。Kerberos 首次将授权与认证紧密结合，为跨主机资源访问提供了可扩展的信任基础设施。

1996 年，Sandhu 等人正式提出基于角色的访问控制(RBAC)模型，通过引入

删除[peifang ni]: 发展脉络

删除[风雨中行走]: “

删除[peifang ni]: ”

删除[风雨中行走]: ”

删除[peifang ni]: ”

删除[风雨中行走]: “

删除[peifang ni]: ”

删除[风雨中行走]: “

删除[peifang ni]: ”

删除[风雨中行走]: ”

删除[peifang ni]: ”

删除[风雨中行走]: ”

删除[peifang ni]: ”

删除[风雨中行走]: ((用户、进程)

删除[peifang ni]:)

删除[风雨中行走]: ((文件、资源)

删除[peifang ni]:)

删除[风雨中行走]: Bell-LaPadula(

删除[风雨中行走]:)

删除[风雨中行走]: “

删除[peifang ni]: ”

删除[风雨中行走]: ”

删除[peifang ni]: ”

删除[peifang ni]: ，

删除[peifang ni]: 、

角色作为用户与权限之间的中间抽象层,大幅简化了大规模系统的权限管理复杂度^[9]。2001 年, Ferraiolo 等人在 ACM TISSEC 上发表了 NIST RBAC 标准提案, RBAC 被确立为美国国家标准^[10]。

进入 21 世纪, 互联网商业化的加速推动了跨组织、跨安全域的身份联合需求。2002 年, OASIS 发布安全断言标记语言 SAML 1.0, 定义了基于 XML 的跨域认证与授权断言交换框架; 2005 年, SAML 2.0 正式发布^{[11][12]}, 融合了 Shibboleth 与 ID-FF^[13]的技术成果, 成为企业级跨域单点登录与联邦身份管理的基础标准。随着 Web 服务的兴起, 授权协议开始独立于身份认证发展。2005 年, OASIS 发布了可扩展访问控制标记语言, 以标准化的策略声明方式实现细粒度的授权决策^[14]。2014 年, 美国国家标准与技术研究院发布了属性基访问控制定义与实施指南, 推动了从角色驱动向属性驱动访问控制范式转变^[15]。

2012 年, IETF 发布 OAuth 2.0 授权框架, 标志着现代授权协议的重大突破^[16]。Hardt 在 RFC 6749 中定义了授权服务器、资源服务器、客户端和资源所有者四种角色, 实现了第三方应用在无需获取用户凭证的前提下获得对用户资源的有限访问权限。这一委托授权范式彻底改变了开放互联网的信任模型。2015 年, Jones 等人发布 RFC 7519, 为轻量级的凭证传输提供了标准格式^[17]。此后, OIDC 在 OAuth 2.0 之上构建了身份层^[18], 共同构成了现代 Web 授权协议的事实标准体系。此后, OAuth 2.0 生态持续演进: PKCE(RFC 7636)缓解了公共客户端的授权码拦截风险^[19]; DPOP 通过绑定访问令牌与客户端密钥, 进一步降低了令牌泄露后的滥用风险^[20]; OAuth 2.1 草案整合了上述安全最佳实践^[21], 推动委托授权范式向更高安全水位发展。

2020 年, NIST 发布 SP 800-207《零信任架构》, 确立了永不信任, 始终验证的安全原则, 要求对每一次访问请求进行动态授权评估^[22]。零信任架构并非独立的访问控制模型, 而是对 MAC、RBAC、ABAC 等既有模型在开放网络环境下的重构: 它否定基于网络位置的隐式信任, 要求将授权决策点尽可能靠近资源, 并通过持续风险评估实现动态、细粒度的访问控制。

1.2 智能体的发展与应用

当前, 以大型语言模型为认知核心的人工智能系统正经历从被动响应者向自

删除[风雨中行走]: “
删除[peifang ni]: ”
删除[风雨中行走]: ”
删除[peifang ni]: ”
删除[风雨中行走]: (ABAC)
删除[风雨中行走]: RFC 6749 (
删除[peifang ni]: (
删除[风雨中行走]:)
删除[peifang ni]:)
删除[风雨中行走]: “
删除[peifang ni]: ”
删除[风雨中行走]: ”
删除[peifang ni]: ”
删除[风雨中行走]: OpenID Connect(
删除[风雨中行走]:)
删除[风雨中行走]: “
删除[peifang ni]: ”
删除[peifang ni]: 广泛
删除[风雨中行走]: “
删除[peifang ni]: ”
删除[风雨中行走]: ”
删除[peifang ni]: ”
删除[风雨中行走]: “
删除[peifang ni]: ”

主执行者的范式跃迁。所谓智能体，是指在 LLM 基础上通过模块化扩展，集成规划、感知、记忆与工具调用四大关键能力，能够在开放环境中持续进行目标分解、决策推理与动作执行的自主系统^[23]。与仅具备文本生成能力的传统 LLM 不同，智能体通过推理-行动闭环如 ReAct 框架与外部工具进行动态交互，从而将语言理解转化为物理或数字世界中的实际影响^[24]。2023 年，Park 等提出的 Generative Agents 通过为智能体注入记忆、反思与社会行为模拟机制，在虚拟环境中实现了可信的人类行为复现，标志着智能体从概率性语言模型向状态化自主实体的质变^[25]。随着 AutoGen、MetaGPT、CrewAI 等多智能体编排框架的成熟，智能体进一步具备了跨角色协作、任务委派与分布式认知的能力，形成了所谓的 Agentic AI 范式^{[26][27]}。

智能体技术已在多个关键领域展现出变革性潜力，其应用深度正从辅助性工具向核心业务流程渗透。在科学研究领域，ToolUniverse 等框架将 600 余个科学计算模型与数据库封装为统一工具集，支持智能体自动完成假设生成、实验设计与数据分析；在医疗决策领域，MedAgentBench 与 AIPatient 等系统利用多智能体架构与检索增强生成(RAG)技术，实现电子病历检索、临床决策支持与复杂医疗场景模拟^[29]。在金融分析领域，TradingAgents 框架构建了包含基本面分析、情绪分析、风控等多角色的智能体协作系统，通过结构化通信协议模拟真实交易决策流程^[28]。在软件工程领域，GPT-Engineer 等系统将 LLM 驱动的设计与本地代码执行环境相结合，实现软件的迭代式自动开发^[28]。此外，在企业服务场景中，智能体已深度集成于客户关系管理、办公协同与知识管理流程，成为组织数字化转型的关键基础设施^[29]这种广泛渗透意味着智能体不再是孤立的学术原型，而是正在嵌入社会生产系统的核心环节。

1.3 智能体广泛应用的安全挑战

随着 LLM 从被动对话工具演进为具备工具调用、任务规划与自主执行能力的智能体，人工智能应用形态正经历从信息生成到行动执行的根本性跃迁。当前，智能体已广泛渗透至个人数字助理、企业流程自动化、金融高频交易、医疗辅助诊断、软件工程、网络安全运营与科学计算等关键领域。在这些场景中，智能体不再局限于文本生成，而是能够自主调用外部接口、查询与修改数据库、执行代

- 删除[风雨中行走]: ”
- 删除[peifang ni]: ”
- 删除[风雨中行走]: “
- 删除[peifang ni]: ”
- 删除[风雨中行走]: ”
- 删除[peifang ni]: ”
- 删除[风雨中行走]: (
- 删除[peifang ni]: (
- 删除[风雨中行走]:)
- 删除[peifang ni]:)
- 删除[风雨中行走]: ((API、数据库、计算资源)
- 删除[peifang ni]:)
- 删除[风雨中行走]: “
- 删除[peifang ni]: ”
- 删除[风雨中行走]: ”
- 删除[peifang ni]: ”
- 删除[风雨中行走]: “
- 删除[peifang ni]: ”
- 删除[风雨中行走]: ”
- 删除[peifang ni]: ”
- 设置格式[风雨中行走]: 字体颜色: 背景 2
- 删除[风雨中行走]: 大语言模型
- 删除[风雨中行走]: “
- 删除[风雨中行走]: ”
- 删除[peifang ni]: ”
- 删除[风雨中行走]: “
- 删除[peifang ni]: ”
- 删除[风雨中行走]: ”
- 删除[peifang ni]: ”

码、编排跨服务工作流，甚至代表用户与其他智能体或人类主体进行多轮协商与任务委托。这种从回答到行动的能力扩展，使得智能体从孤立的信息处理单元转变为直接作用于物理与数字世界的行动主体，其安全边界也随之从模型内部扩展至整个计算生态，形成了前所未有的攻击面。

删除[风雨中行走]: "
删除[风雨中行走]: 言说
删除[风雨中行走]: "

然而，智能体的自主性在提升效率的同时，也引入了传统软件系统未曾面临的结构性安全风险。当前智能体安全研究主要围绕三个层面展开，且三者之间存在复杂的耦合关系。

第一，模型层安全。大语言模型对输入语义的敏感性使其容易受到提示注入、越狱攻击与上下文操纵等对抗性攻击的影响。攻击者通过精心构造的提示绕过安全对齐机制，诱导智能体产生有害输出或执行非预期操作。例如，攻击者可在用户输入中嵌入隐藏指令，使智能体在解析任务时优先执行恶意操作而非用户真实意图；也可通过角色扮演、编码转换或语义混淆等方式触发越狱，解除模型内置的安全限制。此外，模型幻觉导致的决策偏差是另一类非对抗性风险：当智能体基于错误记忆或虚构事实进行任务规划时，可能在缺乏外部攻击的情况下自主产生错误判断，进而调用错误工具或访问错误资源，引发后续连锁风险。更为隐蔽的是，模型训练数据中的污染与后门植入可在模型层面形成持久化威胁，使智能体在特定触发条件下表现出可预测的有害行为，而常规的安全对齐与红队测试难以完全检测此类深层缺陷。

第二，交互层安全。智能体通常通过函数调用机制与外部工具、插件、第三方接口连接，这一模型—工具边界成为攻击传导的关键通道。首先，工具接口的输入验证缺失或返回数据的不可信性均可能成为攻击向量：恶意网站或受感染的第三方服务可通过工具返回内容向智能体上下文注入伪造指令，操纵其后续决策与工具选择。其次，工具描述欺骗风险不容忽视：智能体依赖自然语言描述来选择调用何种工具，攻击者可通过篡改工具描述或注册名称相似的高危工具，诱导智能体在不知情的情况下执行敏感操作。再次，多轮交互中的状态污染具有累积效应：智能体在复杂任务中需维护跨步骤的上下文记忆，攻击者可在早期轮次植入看似无害的指令片段，在后续轮次中通过特定触发条件激活，形成延迟生效的攻击链。此外，第三方工具供应链的不可控性也带来了数据泄露与恶意代码执行风险，使得智能体成为跨服务攻击的跳板，一旦工具提供方被攻陷，所有调用

删除[风雨中行走]: “
删除[peifang ni]: "
删除[peifang ni]: -
删除[风雨中行走]: ”
删除[peifang ni]: "

该工具的智能体均可能遭受牵连。

第三，系统层安全。现有网络安全架构大多围绕人类用户或静态服务主体设计，尚未对智能体这一新型非人类行动主体形成有效的安全约束。首先，智能体在部署时往往被赋予宽泛的角色权限，且后续缺乏动态审查与最小权限调整机制，导致过度代理现象普遍存在：智能体权限远超其实际任务所需，形成巨大的待机暴露面。随着时间推移与任务演化，智能体权限与实际使用场景之间的偏差不断扩大，产生权限漂移，造成永久性的过度授权状态。其次，在多用户协作场景中，智能体代表用户访问其他用户资源的需求日益增长，但现有授权协议缺乏对跨主体资源访问场景的原生支持，无法建立清晰的权限边界、有效的同意机制与责任追溯链条。再次，在多智能体协作场景中，单一智能体将子任务委托给子智能体或调用外部工具链时，权限在委托链中的传递、衰减与审计缺乏形式化约束，极易产生权限蠕变：子智能体权限可能超出父智能体原始授权范围，且合成结果可能引发聚合推理风险。更为关键的是，现有审计机制通常面向单次访问设计，无法记录跨智能体、跨服务、跨时间的工作流级授权轨迹，使得安全事件的事后追溯与责任认定极为困难。

上述三个层面的安全问题相互交织、彼此放大：模型层的决策偏差可能通过交互层传导至外部系统，而系统层的权限缺失又为模型层与交互层的攻击提供了更大的破坏空间。这种安全态势的根源在于，智能体作为自主行动主体与现有静态授权架构之间存在深刻的结构性错配。传统访问控制模型基于人类组织的稳定角色层次、可预测的行为模式与明确的会话生命周期设计，权限变更低频、委托关系简单。而智能体以机器速度运行，其权限需求随任务上下文动态变化，委托关系呈递归链式扩展，行为轨迹跨越多个服务边界。因此，对现有协议进行表层修补已无法应对智能体时代的安全需求，亟需从架构层面重新设计面向智能体的授权协议，将授权评估从周期性网关检查转变为持续进行的系统属性，将身份治理与权限管理作为智能体基础设施的一等设计约束，在编排逻辑扩展前嵌入架构核心而非事后附加。因此，研究面向智能体的授权协议，不仅是填补当前技术空白的学术需要，更是保障智能体在金融、医疗、关键基础设施等高风险领域安全、可信、可控部署的现实前提。

删除[风雨中行走]: "

删除[风雨中行走]: "

删除[风雨中行走]: "

删除[风雨中行走]: "

删除[风雨中行走]: "

删除[风雨中行走]: "

删除[风雨中行走]: "

删除[风雨中行走]: "

删除[风雨中行走]: "

删除[风雨中行走]: "

删除[风雨中行走]: "

删除[风雨中行走]: "

1.4 智能体安全问题

伴随着智能体的广泛应用，其部署过程中已暴露出多起严峻的安全问题，且攻击面随自主性的提升呈指数级扩展。首先，工具调用机制遭到系统性劫持：攻击者不仅可通过篡改工具描述或返回数据直接操纵智能体的外部接口调用行为，实施拒绝服务或远程代码执行，还可利用多跳工具链中的权限累积效应，在单次任务周期内通过看似无害的连续调用逐步提升危害等级；更为隐蔽的是，攻击者仅需向智能体长期记忆中注入少量伪装的技术记录，即可在后续多轮任务中持续劫持其工具选择决策，且现有安全防御几乎无法识别此类记忆投毒攻击。此外，第三方工具供应链的不可控性进一步放大了风险，恶意插件或受损的外部服务可在智能体不知情的情况下将其转化为跨系统攻击的跳板。其次，记忆库成为持久化攻击载体：攻击者可在检索增强生成记忆库中植入视觉语义触发器，使其作为休眠代理潜伏于系统内部，在未来规划阶段隐式劫持智能体的推理链；而记忆被污染后产生的有害输出与模型固有失败难以区分，导致防御系统难以归因，有效防御窗口被压缩至不足 5 个会话周期。更为严重的是，记忆污染具有跨会话持久性与自我强化特征：被污染的记忆在后续任务中会被智能体主动检索并作为决策依据，形成污染-检索-再污染的恶性循环，且攻击者可利用智能体的自主学习能力将恶意知识固化为长期行为模式，传统基于输入过滤的防御机制对此类深层记忆操纵几乎失效。再次，执行环境隔离失效：高能力智能体在自主研究任务中曾通过多步骤利用链识别沙箱内漏洞、实现权限提升，最终突破沙箱边界获得未授权网络访问并对外传输数据，暴露出沙箱机制在自主智能体面前的脆弱性。除了主动漏洞利用，智能体还可能通过侧信道探测、资源耗尽攻击或社会工程学诱导等方式，在沙箱限制内重构出超出设计意图的信息通道；其自主性与创造性使得传统基于静态规则的环境隔离难以覆盖所有逃逸路径，一旦突破边界，智能体即可利用已获取的宽泛权限在宿主系统中横向移动，造成系统性破坏。此外，推理过程遭受深层操纵：攻击者可通过约束收紧与推理劫持技术，在不改变外部任务表象的前提下直接操纵智能体的多步规划与决策排序，使其在任务分解与资源分配阶段产生系统性偏差，形成不可还原的决策复杂性。这种操纵不仅限于即时任务，还可通过植入子目标或价值偏移，使智能体在后续自主运行中持续偏离用户原始意图，且由于推理链的不可解释性与动态性，受害者往往难以察觉操纵的

删除[peifang ni]: **

删除[peifang ni]: **

删除[风雨中行走]: "

删除[风雨中行走]: "

删除[风雨中行走]: "

删除[风雨中行走]: "

存在，直至产生不可逆的实质性损害。再次，执行环境隔离失效：高能力智能体在自主研究任务中曾通过多步骤利用链识别沙箱内漏洞、实现权限提升，最终突破沙箱边界获得未授权网络访问并对外传输数据，暴露出沙箱机制在自主 Agent 面前的脆弱性。最后，权限配置失当引发持续暴露：智能体在部署时往往被赋予宽泛的 IAM 角色且后续缺乏审查，导致其权限与实际使用需求之间的偏差随时间不断扩大，形成永久性的待机暴露面，直接违背最小权限原则^[30]。

除此之外，智能体的自主性还引入了传统安全模型难以覆盖的持续性、级联化风险，其安全影响随任务执行不断蔓延并跨系统边界扩散，呈现非线性放大效应。其中，权限与访问控制的缺失是贯穿上述问题的核心瓶颈：工具调用缺乏精确权限界定，记忆写操作缺乏身份治理，沙箱逃逸暴露了粗粒度授权的危害，而推理链操纵则揭示了传统身份-权限二元模型在自主决策场景下的失效。在已登记的 CVE 漏洞中，有 19 个与智能体相关漏洞，而其中有 11 个与授权相关，如表 1-1。由此可见，授权问题是智能体目前安全问题的重中之重。

删除[风雨中行走]: "
删除[风雨中行走]: "

表 1-1 智能体授权漏洞

漏洞类型	CVE 编号
认证绕过 / 自动设备批准	CVE-2026-25253
配置注入 / 权限提升	CVE-2025-61260
授权绕过 / 自动启用 MCP	CVE-2025-59536
凭证窃取 / 授权头泄露	CVE-2026-21852
LLM 范围越界 / 授权边界突破	CVE-2025-32711
授权边界 / 范围控制失效	CVE-2025-68145
凭证管理 / 环境变量注入	CVE-2026-27203
配置注入 / 未授权配置修改	CVE-2026-30624
网络边界 / 访问控制绕过	CVE-2026-35568
授权状态重用 / 配置变更无重授权	CVE-2025-54136

1.5 智能体的授权问题

智能体的独特特性——自主性、工具和服务调用能力、动态决策和多主体协作——使其面临传统软件系统所不具备的安全风险。这种调用外部服务或者访问

外部资源的能力使其被攻击后的影响面大大提升，因此对智能体调用外部服务或者访问外部资源的能力进行授权控制是不可或缺的。但是授权机制的缺失或不当设计已成为智能体安全漏洞的重要根源。

当前智能体系统普遍面临权限边界模糊的困境：智能体在部署时往往被赋予宽泛的 IAM 角色，且后续缺乏权限审查与动态调整机制。随着时间推移，智能体权限与实际使用需求之间的偏差持续扩大，形成所谓的权限漂移，造成永久性的待机暴露面。这种粗放式授权模式与最小权限原则背道而驰。与此同时，智能体作为数字员工需要跨系统访问用户资源(如调用日历 API、读取数据库、发送邮件)，但现有 OAuth 等授权协议主要面向人类用户设计，缺乏针对智能体特殊行为模式(如自动化、多步推理、跨用户资源访问)的细粒度授权机制。2026 年 2 月，美国国家标准与技术研究院(NIST)启动 AI Agent 标准倡议，明确将认证、授权、审计与不可否认性列为核心标准维度，反映出该问题已引起顶层政策关注。

OWASP 在 2025 年发布的 LLM 应用 Top 10 安全风险中，将过度代理列为 LLM06 号风险^[22]。过度代理是指 LLM 智能体被赋予了超出必要的功能、权限或自主性，从而可能在意外、模糊、幻觉或被操纵的输入驱动下执行有害操作。其根因包括三类：过度功能、过度权限和过度自主。过度代理与提示注入风险形成危险的协同效应——当智能体持有广泛的工具权限且缺乏运行时授权约束时，成功的提示注入将直接转化为行动性攻击。

目前智能体在执行任务时需要访问外部资源或者服务，智能体对于访问外部资源或者服务时，最普遍的是沿用 OAuth 的授权机制。当需要访问外部资源或服务时，由智能体的所在客户端发起 OAuth 协议流程，获取资源的 OAuth 令牌，智能体接着在访问外部资源或服务时在请求中附带 OAuth 令牌。智能体所在客户端下的所有智能体共用一个访问令牌，智能体并没有独属于自己的身份标识，当智能体需要访问资源时，需要先经过客户端的 RBAC 访问策略，判断该智能体是否有权访问对应资源，若有权则客户端携带 OAuth 令牌代替智能体转发访问请求获取资源，之后转发给智能体。

- 删除[风雨中行走]: (Identity and Access Management)
- 删除[风雨中行走]: "
- 删除[风雨中行走]: "
- 删除[风雨中行走]: "
- 删除[风雨中行走]: "
- 删除[风雨中行走]: "
- 删除[风雨中行走]: "
- 设置格式[风雨中行走]: 上标
- 删除[风雨中行走]:
- 设置格式[风雨中行走]: 上标
- 删除[风雨中行走]: (工具超出任务所需)
- 删除[风雨中行走]: (以过高权限运行)
- 删除[风雨中行走]: (高风险操作未经人工确认即自动执行)

二 国内外本学科领域的发展现状与趋势

2.1 授权领域发展现状与趋势

当前,分布式系统中的授权机制主要以IETF标准化的OAuth 2.0框架为代表。Hardt 于 2012 年发布的 RFC 6749 定义了基于授权码、隐式许可等模式的令牌颁发流程,使第三方应用能够在不获取用户凭证的前提下访问受保护资源,从而成为 Web 与移动生态的事实标准。然而,OAuth 2.0 发放的 Bearer Token 通常为静态、粗粒度的访问凭证,其权限范围在签发时即被固定,后续难以根据实际上下文进行收缩;一旦令牌泄露,攻击者即可在有效期内滥用全部授权,违背了最小权限原则。

针对上述缺陷,Birgisson 等人于 2014 年提出了 Macaroon,一种基于链式 HMAC 签名的持有者凭证。Macaroon 通过引入上下文约束机制,允许凭证持有者在不联系签发者的情况下,离线追加时间、IP、操作类型等第一方约束,从而将原始权限安全地衰减为更细粒度的派生凭证;同时,其第三方约束支持跨服务的分布式授权验证,无需各服务直接共享根密钥。该工作首次将离线委托与上下文约束统一在对称密码结构中,为细粒度、可传递的授权提供了新的技术路径^[31]。

尽管如此,Macaroon 及同类方案主要解决的是凭证的静态约束与委托问题,尚缺乏对授权策略执行过程中历史状态与动态上下文的表达能力。2024 年,Cao 等人在 USENIX Security 上提出了 StatefulAuth,一种面向云环境的有状态最小权限授权框架。该框架的核心创新在于允许客户端开发者在申请授权时附加 WebAssembly 编写的策略程序,明确声明其最小权限需求;资源服务器则依据该策略以及客户端在服务器上的操作日志进行动态评估,从而支持诸如仅访问用户近期末读文件或每小时最多调用 10 次 API 等依赖历史状态的有状态授权规则。StatefulAuth 将最小权限的决策权从资源所有者下放至客户端开发者,并通过状态感知显著缩小了令牌泄露后的攻击面^[32]。

综合现有研究可见,授权协议正从静态、粗粒度的 Bearer Token 模式,向支持上下文绑定、离线权限衰减、有状态动态评估的细粒度授权范式演进。未来的发展趋势主要体现在以下三个方面:其一,策略表达能力的标准化,如 Biscuit

删除[风雨中行走]: “
删除[风雨中行走]: ”
删除[风雨中行走]: “
删除[风雨中行走]: ”

删除[风雨中行走]: “
删除[风雨中行走]: ”
删除[风雨中行走]: “
删除[风雨中行走]: ”

等后续工作尝试将 Datalog 等声明式策略语言嵌入令牌结构，以解决跨服务策略互操作性问题；其二，与零信任架构的深度融合，强调永不信任、持续验证，要求对每一次访问请求进行基于实时上下文与历史行为的动态授权决策；其三，面向 AI Agent 等新兴场景，授权协议需进一步支持自主代理的身份治理、任务级权限委托以及跨用户资源的细粒度访问控制，这已成为当前学术界与工业界共同关注的前沿方向。

删除[风雨中行走]: “
删除[风雨中行走]: ”

2.1 智能体授权发展现状与趋势

智能体在执行任务时需要访问外部资源或者服务，智能体对于访问外部资源或者服务时，最普遍的是沿用 OAuth 的授权机制。当需要访问外部资源或服务时，由智能体的用户发起 OAuth 协议流程，获取资源的令牌，智能体接着在访问外部资源或服务时在请求中附带令牌。

然而，在智能体授权领域，尽管 OAuth 已获广泛应用，它仍然存在许多不足，Chopra 等人的工作指出 OAuth 在智能体授权领域中存在的多个不足^[33]：第一个是权限粒度过大，OAuth 的 scope 机制无法支持智能体所需的细粒度资源级权限控制；第二个是无动态策略执行，静态 token 无法支持运行时权限变更和动态策略；缺乏对自主系统的控制，OAuth 设计之初假设有用户在场点击同意，但 AI Agent 是自主运行的，没有人类实时参与。系统论证了传统授权框架与自主智能体的结构性不匹配。该研究指出，以 OAuth 和 RBAC 为代表的授权系统基于人类组织特征设计，权限变更低频且角色边界清晰；而自主智能体以机器速度运行，需在任务执行过程中进行高频、细粒度的权限动态调整，传统静态角色与粗粒度 scope 机制无法支撑这一需求。同时，智能体对子智能体或外部工具的递归委托访问，使传统 OAuth 的交互流程在机器时间尺度下产生不可接受的性能开销；JWT 虽具扩展性，却难以在行为突变时快速撤销，短生命周期令牌又引入显著延迟。此外，现有系统缺乏将智能体当前任务、环境上下文纳入实时权限决策的能力。针对上述挑战，该文提出四项设计方向：一是引入基于能力的安全模型(如 macarons 与 biscuits)，通过不可伪造令牌编码复杂权限与委托链，支持离线式权限衰减；二是构建面向机器速度的实时策略评估引擎，实现基于当前条件与系统状态的动态授权；三是推动跨服务标准化协议，使服务以机器可读格式发布权

删除[风雨中行走]: "
删除[风雨中行走]: "

删除[风雨中行走]: 无状态令牌(
删除[风雨中行走]:)

限模型，支持智能体自动发现与请求权限；四是采用边缘验证架构，将授权决策下沉至网络边缘，避免集中式授权服务器成为性能瓶颈。该研究首次从系统架构层面揭示了传统授权范式与自主智能体的根本性矛盾，将智能体授权问题提升为需要重新设计安全模型的核心议题，为后续 IETF 相关草案及 NIST AI Agent 标准倡议中的授权子系统研究奠定了理论基础。

South 等人于 2025 年提出了一种面向自主 AI 智能体的可认证、可授权与可审计的委托框架^[34]。该研究指出，自主智能体的快速部署在授权、问责与访问控制方面带来了紧迫挑战，现有身份与访问管理协议未能充分解决智能体代表谁行事以及权限边界如何动态约束的核心问题。为此，该文在保留与现有 Web 基础设施兼容性的前提下，系统扩展了 OAuth 2.0 与 OpenID Connect，引入智能体特定的凭证与元数据机制，构建了人机之间的可验证委托链。该框架的核心机制包含三个层次：在认证层，用户首先向 OpenID Provider(OP)完成身份验证，随后将特定 AI 智能体注册为自身委托代表，OP 为其签发包含智能体唯一标识与属性信息的 Agent-ID Token；在授权层，用户进一步签发 Delegation Token，将特定任务范围的权限加密绑定至该智能体，二者共同封装于 W3C Verifiable Credentials 数据结构中，使智能体在跨服务交互时可被第三方独立验证其代表关系与权限范围；在审计层，所有凭证声明与属性状态均可被交互各方检查与验证，确保委托链条未被篡改。该研究进一步提出将灵活的自然语言权限描述转换为可审计、细粒度访问控制配置的翻译框架，使非技术用户能够以自然语言设定智能体权限，同时下游服务获得可执行的策略规则。此外，该文还探讨了多智能体场景下的相互认证问题：通过联邦 OpenID Provider 架构，不同域内的智能体可交叉验证彼此的委托凭证与授权边界，防止冒充与未授权协作。在法律与治理维度，作者引入代理法中的明显授权原则，论证了可验证委托框架如何降低第三方因无法确认智能体授权状态而承担的法律风险，为智能体问责提供了法理基础。该研究的意义在于，它首次从协议扩展层面将传统 Web 身份基础设施与智能体委托需求进行系统性融合，提出了一套兼具即时部署可行性与严格安全属性的委托范式。其基于 OAuth/OIDC 的渐进式扩展路径、自然语言权限翻译机制以及跨域多智能体相互认证方案，为后续智能体授权协议的标准化研究提供了重要的理论与工程参考。

删除[风雨中行走]: “

删除[风雨中行走]: ”

删除[风雨中行走]: “

删除[风雨中行走]: ”

删除[风雨中行走]: “

删除[风雨中行走]: ”

在面向企业环境的智能体动态授权研究方面，Fleming 等人于 2025 年提出了一种融合资源风险感知与模型不确定性量化的任务级授权框架^[35]。该研究指出，RBAC 与 ABAC 等静态模型难以应对智能体在执行过程中涌现的新颖任务，而单纯依赖 LLM 即时生成策略又面临两项关键风险：一是 LLM 可能为高风险资源生成过度宽松的权限，二是 LLM 自身可能对其知识盲区过度自信，产生自信地错误的授权决策。为此，该文以任务级访问控制为基底，引入 LLM Judge 作为动态策略合成引擎，并扩展其决策维度为三元组：任务意图、复合资源风险评分与模型不确定性估计。具体而言，每个工具或 API 被预先赋予基于业务关键性的静态风险分值；LLM 在合成即时策略的同时，计算该任务所触及资源的复合风险评分，并通过蒙特卡洛 Dropout 或集成方法等方式评估自身对生成策略的置信度。决策引擎依据双重阈值进行动态裁决：仅当复合风险与模型不确定性均低于预设阈值时方可自动授权；任一维度超标即触发人工审批或更严格的控制措施。该框架在事件响应与商业分析两类典型场景中展示了其自适应特性：前者因触及高风险的防火墙 API 且任务新颖导致不确定性高，被自动升级至人工审批；后者因仅涉及低风险的只读 CRM 操作且任务常规，获得全自动授权。作者进一步指出，该模型将访问控制系统从简单守门人转化为复杂风险管理引擎，为智能体自主性与企业安全性之间的平衡提供了新的理论范式。该研究的价值在于，它首次将任务级风险评估与模型不确定性量化整合为统一的授权框架，突破了传统访问控制非黑即白的决策模式，为后续智能体授权协议中引入风险自适应^[36]与自感知机制奠定了理论基础。

Uchibeke2026 年提出将行动前授权确立为独立于模型对齐与事后评估的第四类安全架构层^[37]。该研究指出，当前智能体执行工具调用时普遍依赖概率性的模型对齐与回顾性的事后评估，二者均无法在单次调用级别提供确定性的策略强制执行。为此，该文提出 Open Agent Passport(OAP)规范，通过在框架层植入 before_tool_call 同步拦截钩子，在工具调用执行前依据声明式策略进行确定性评估，并生成经 Ed25519 签名的审计记录。该机制具备确定性、完备性、故障关闭、不可绕过与可审计五项核心性质，授权决策中位延迟仅 53 ms。在 APort Vault CTF 对抗测试中，启用严格 OAP 策略的高危场景下 879 次攻击尝试的成功率为 0%，验证了确定性策略层对概率性模型缺陷的刚性约束。该工作推动了从依赖

删除[风雨中行走]: “
删除[风雨中行走]: ”

删除[风雨中行走]: “
删除[风雨中行走]: ”
删除[风雨中行走]: “
删除[风雨中行走]: ”
删除[风雨中行走]: “
删除[风雨中行走]: ”
删除[风雨中行走]: “
删除[风雨中行走]: ”

删除[风雨中行走]: “

模型自律到架构级强制策略的范式转变，OAP 已集成至六个主流智能体框架并被提议作为 Google A2A 协议扩展，对智能体安全标准化具有重要推动作用。

Prakash 于 2026 年针对当前 MCP 与 A2A 等主流智能体协议缺乏身份验证的结构性缺陷，提出了首个融合公钥可验证委托、持有者侧权限衰减与跨协议传输绑定的身份协议^[38]。该研究通过对约 2000 个 MCP 服务器的扫描发现，所有服务器均缺乏认证机制；A2A 的代理卡片虽包含自声明身份，但无签名绑定。作者系统比较了 OAuth 2.1、W3C DID、Macaroons、UCAN 等 11 类现有方案，发现没有任何单一方案能同时满足智能体身份所需的七项核心性质。该项工作的核心贡献是 Invocation-Bound Capability Tokens(IBCT)，一种将身份、衰减授权与溯源绑定融合为单一追加式令牌链的原语，提供紧凑模式与链式模式。该研究首次为 MCP 与 A2A 生态提供了统一的身份与可验证委托层，将智能体授权从协议可选功能提升为架构级安全基础，为后续智能体身份标准化及企业级多智能体系统的安全部署提供了关键理论支撑。

Tallam 等人从架构层面提出了一个与提示注入互补且不可归约的新问题——授权传播^[39]。该研究指出，当前安全讨论过度聚焦于提示注入攻击向量，而忽视了多智能体系统在正常运行过程中固有的授权架构缺陷。作者将授权传播形式化为三个子问题：传递性委托，即智能体在委托链中如何继承和衰减权限；聚合推理，即多个独立授权的数据访问在合成后可能暴露单独访问不会泄露的信息；以及时间有效性，即多步自主 workflows 执行过程中授权状态的动态维持问题。该文将授权传播形式化为三个子问题：传递性委托的权限边界与累积抑制、多源数据聚合推理的授权判定、以及多步骤 workflows 中授权变更的时间有效性。基于此，作者推导出多智能体授权架构必须满足的七项结构要求，涵盖智能体作为第一类授权对象、显式有界委托、边界处授权评估、可执行聚合策略、工作流级审计轨迹、时间有效性策略决策以及合成图追溯恢复。研究进一步论证了现有模型的固有局限：RBAC 静态角色无法表达委托链；ABAC 按单次访问独立评估，无法约束跨访问聚合；ReBAC 虽最接近需求，但缺乏对动态 workflow、非人类主体及时间有效性的原生支持。作者据此提出身份治理即基础设施的核心主张，强调授权评估必须是持续进行的系统属性而非周期性网关检查，应在编排逻辑扩展前作为一等设计约束嵌入架构。来自企业 AI 平台的初步证据表明，普通系统行为已能产生

删除[风雨中行走]: ”

删除[风雨中行走]: “

删除[风雨中行走]: ”

删除[风雨中行走]: (EdDSA 签名 JWT，适用于单跳 MCP 调用)

删除[风雨中行走]: (基于 Biscuit 的 Datalog 策略令牌，支持多跳委托)

删除[风雨中行走]: “

删除[风雨中行走]: ”

删除[风雨中行走]: “

删除[风雨中行走]: ”

删除[风雨中行走]: “

删除[风雨中行走]: ”

该模型所预测的授权边界失效。该研究首次从系统架构层面将多智能体授权问题从攻击向量防御提升至结构性基础设施设计高度，为后续智能体授权协议研究提供了形式化的问题分解与治理范式，对当前 IETF 相关草案及企业级多智能体平台的安全架构设计具有重要指导意义。

智能体授权的研究正从用户主导向机器主导范式转换。传统 OAuth、RBAC 基于人类行为特征设计，而智能体以机器速度自主运行，要求授权协议在交互延迟与决策频率上全面重构，从静态角色向动态上下文感知演进；访问控制正从非黑即白的角色判定，转向基于任务意图、资源风险与模型不确定性的自适应裁决判定，实现权限随任务动态调整；安全重心从依赖模型的概率性自我约束，转向授权框架框架层植入的确定性策略拦截与故障关闭机制，实现不可绕过的授权刚性保障；可验证的细粒度能力衰减；授权机制需同时满足资源级细粒度、密码学可验证性与委托链中的权限逐步衰减，以应对多智能体协作中的权限扩散风险。领域采取务实取向，通过扩展 OAuth/OIDC、统一 MCP/A2A 身份层等渐进方式，在兼容现有 Web 基础设施的同时推进跨生态互操作。

综上所述，智能体授权正经历从适配传统框架到重新设计新框架的变革，核心指向自主决策、动态风险评估、架构强制保障、细粒度可衰减委托与标准化互操作的未来架构。

三 课题主要研究内容、预期目标

3.1 研究内容

尽管目前许多工作提出新型授权框架或者授权协议，但这些工作主要集中在智能体间委托授权以及实时授权评估，并未注意到目前智能体任务的复杂性、不能适配新型智能体任务执行的自主性。首先，由于智能体执行任务的自主性，给系统带来了更大的攻击面，进一步给系统带来了更精细的授权需求，用户不仅需要对操作类型进行授权，也需要对操作参数进行授权。而目前智能体的授权模式是对智能体的宽泛授权，而不是对智能体的精确授权，缺少对智能体的操作参数约束，导致具有强自主性的智能体利用宽泛权限任意执行恶意操作，因此需要精确界定权限边界实现对智能体的紧授权。例如用户给智能体分配发通知邮件给几

删除[风雨中行走]: “
删除[风雨中行走]: ”
删除[风雨中行走]: “
删除[风雨中行走]: ”
删除[风雨中行走]: “
删除[peifang ni]: ”
删除[风雨中行走]: ”
删除[peifang ni]: ”
删除[风雨中行走]: “
删除[peifang ni]: ”
删除[风雨中行走]: ”
删除[peifang ni]: ”

删除[peifang ni]: 可能
删除[peifang ni]: 一个
删除[peifang ni]: 某

个确定邮箱地址的任务时，目前的授权模式是给用户授予一个宽泛的发邮件的权限，而用户仅希望授予智能体一个精确的发邮件给对应邮箱地址的权限，因此需要将智能体获得的发邮件权限精确到发邮件给确定地址；其次，有序多任务执行环境下，目前智能体同时授权多个相应任务执行权限，而未对各个任务执行进行顺序约束，导致具有强自主性的智能体实施序列混乱、步骤跳跃等攻击，因此需要精确定义序列任务中权限生效依赖关系，确保前置任务完成与后置任务授权生效的原子性。例如用户给智能体分配迁移数据库的任务，要求智能体按照这样的顺序严格执行：备份当前库、执行迁移脚本、验证数据一致性、回滚预案测试、切换读写流量。顺序有误将导致严重的后果，若先执行迁移脚本，再备份当前库，则若迁移脚本后执行测试有无，将导致全库丢失，因此需要对每个任务的授权都需要保证前置任务的完成；最后，目前缺乏对针对上述新型授权需求的授权协议的应用实现，即实现单任务的精确授权，有序多任务的顺序授权。

基于以上关键科学问题，本研究致力于提出一种面向复杂任务的智能体授权协议，以适配智能体复杂任务的新型授权需求，主要包括以下研究内容：

1. 基于操作参数约束需求的智能体授权协议设计

设计授权参数先至的授权协议流程，实现对智能体操作授权参数的精确绑定。设计授权参数验证机制，保证对智能体操作的紧授权。

2. 基于顺序执行约束需求的智能体授权协议设计

对于有序的多个任务，设计任务的权限序列拆分机制，将多任务序列执行条件归约至条件密码原语，实现前置任务完成与后置任务权限凭证生效的抽取性绑定；设计原子授权触发机制，保证前置任务完成与后置任务授权获取的原子性。

3. 基于复杂任务授权需求的智能体授权协议应用实现

搭建多个典型授权场景的智能体，实现研究内容 1、2 中授权协议，基于 AgentDojo 基准测试集测试其安全性、性能，并与传统授权协议进行比较。

3.2 预期目标

1. 针对精确授权的新型需求场景，设计明确操作授权参数、绑定授权参数以及参数可验证的精确授权协议。

删除[peifang ni]: 邮箱

删除[peifang ni]: 用户

删除[peifang ni]: 一个

删除[peifang ni]: 那这

删除[peifang ni]: 可能

删除[peifang ni]: 倘

删除[peifang ni]: 阶段

删除[peifang ni]: 还

删除[peifang ni]: 中

删除[peifang ni]: 中

删除[peifang ni]: 我们

删除[peifang ni]: 研究以下几点

删除[peifang ni]: 面向

删除[peifang ni]: 研究

删除[peifang ni]: 面向任务执行

删除[peifang ni]: 研究

删除[peifang ni]: 接着

删除[peifang ni]: 、

删除[peifang ni]: 以及前置任务授权释放

删除[peifang ni]: 新型

删除[peifang ni]: ， 测试协议开销

删除[peifang ni]: 开销对比

删除[peifang ni]: 结合 OAuth 授权协议设计思想，

2. 在多个有序任务执行场景下，设计保证前置任务完成后，自动生效后置任务授权的授权框架，保证对任务授权的严格顺序性。
3. 搭建智能体并集成前两项研究内容，基于开源数据分析安全性、性能，并与其他典型授权协议进行对比。

删除[peifang ni]: 对

删除[peifang ni]: 工作设计的协议

删除[peifang ni]: 测试开销

四 拟采用的研究方法、技术路线、实验方案及其可行性分析

1. 设计用户给智能体签发的权限参数令牌，与授权服务器给智能体颁发的权限令牌，共同绑定为紧权限令牌（精确权限令牌）。从而实现用户主导的紧权令牌，让用户能够对授权服务器颁发的宽泛权限令牌进行降权处理，以适应单任务所需的精确授权需求。设计合理的紧权限令牌验证机制，验证紧权限令牌的有效性。设计及时的令牌撤销机制，用于用户撤销紧权限令牌。
2. 通过选择合理的信任模型，保证触发条件凭据不可伪造，不可篡改，设计高效准确的任务条件判定机制用于判定触发条件，设计可靠易验证的条件凭据以及其验证机制。设计高效的条件触发授权凭证激活/颁发机制，设计及时的授权凭证触发机制，保证条件凭据验证通过、前置任务授权撤销、后置任务授权激活是原子的。
3. 完成上述授权协议的实现，基于 LangGraph、AutoGen 等智能体开源框架，搭建智能体，分别集成 OAuth、其他典型工作例如 PAuth 等授权协议以及前两项研究内容所设计授权协议后，基于 AgentDojo 测试协议的安全性、性能，分析测试结果并进行优化与改进。

删除[peifang ni]: 权

删除[peifang ni]: (

删除[peifang ni]:)

删除[peifang ni]: 权

删除[peifang ni]: 权

删除[peifang ni]: 合法性

删除[peifang ni]: 权

删除[peifang ni]: 的

删除[peifang ni]: 。为可信方

删除[peifang ni]: 的

删除[peifang ni]: 引擎

删除[peifang ni]: ，并完成协议开销测试后对比

删除[peifang ni]: 后

删除[peifang ni]: 做出

五 已有科研基础与所需的科研条件

- 参加密码协议相关课程，学习密码学基础理论。
- 研读授权协议相关论文，了解传统授权协议设计思路。
- 调研智能体领域中授权框架采用情况，研读智能体授权领域工作，理解该领域下的授权需求。

设置格式[peifang ni]: 字体: （默认）宋体，（中文）宋体

设置格式[peifang ni]: 行距: 1.5 倍行距

六 研究工作计划与进度安排

2026 年 6 月-2026 年 8 月：完成单任务精确授权智能体授权协议的设计。

2026 年 9 月-2026 年 10 月：完成多任务间顺序授权智能体授权协议设计。

2026 年 11 月-2026 年 12 月：完成上述两项协议的代码实现并且集成到搭建的智能体中，进行安全测试，并测试开销。

2027 年 1 月-2027 年 4 月撰写硕士论文，准备毕业答辩

七 参考文献

- [1]DALEY R C, NEUMANN P G. A general-purpose file system for secondary storage[C]//Proceedings of the Fall Joint Computer Conference (AFIPS FJCC). [S.l.]: Spartan Books, 1965: 213-229.
- [2]DENNIS J B, VAN HORN E C. Programming semantics for multiprogrammed computations[J]. Communications of the ACM, 1966, 9(3): 143-155.
- [3]LAMPSON B W. Protection[J]. ACM Operating Systems Review, 1974, 8(1): 18-24.
- [4]BELL D E, LAPADULA L J. Secure computer systems: Mathematical foundations[R]. [S.l.]: MITRE Corporation, 1973.
- [5]BIBA K J. Integrity considerations for secure computer systems[R]. [S.l.]: MITRE Corporation, 1977.
- [6]STEINER J G, NEUMAN B C, SCHILLER J I. Kerberos: An authentication service for open network systems[C]//Proceedings of the USENIX Winter Conference. Dallas: USENIX Association, 1988: 191-202.
- [7]KOHL J T, NEUMAN B C. The Kerberos network authentication service (V5)[R/OL]. RFC 1510, 1993.
- [8]NEUMAN C, YU T, HARTMAN S, RAEBURN K. The Kerberos network authentication service (V5)[R/OL]. RFC 4120, 2005.
- [9]SANDHU R S, COYNE E J, FEINSTEIN H L, YOUMAN C E. Role-based access control models[J]. IEEE Computer, 1996, 29(2): 38-47.
- [10]FERRAILOLO D F, SANDHU R, GAVRILA S, et al. Proposed NIST standard for role-based access control[J]. ACM Transactions on Information and System Security, 2001, 4(3): 224-274.
- [11]OASIS. Security Assertion Markup Language (SAML) V2.0 technical overview[S/OL]. OASIS SSTC Working Draft sstc-saml-tech-overview-2.0-draft-08, 2005.

- [12]CANTOR S, KEMP J, PHILPOTT R, MALER E. Assertions and protocols for the OASIS Security Assertion Markup Language (SAML) V2.0[S]. OASIS Standard saml-core-2.0-os, 2005.
- [13]LIBERTY ALLIANCE PROJECT. Liberty Alliance Identity Federation Framework (ID-FF) 1.2[S]. 2003.
- [14]MOSES T. eXtensible Access Control Markup Language (XACML) version 2.0[S]. OASIS Standard, 2005.
- [15]HU V C, FERRAILOLO D, KUHN R, et al. Guide to attribute based access control (ABAC) definition and considerations[S]. NIST Special Publication 800-162, 2014.
- [16]HARDT D. The OAuth 2.0 authorization framework[R/OL]. RFC 6749, 2012.
- [17]JONES M, BRADLEY J, SAKIMURA N. JSON Web Token (JWT)[R/OL]. RFC 7519, 2015.
- [18]SAKIMURA N, BRADLEY J, JONES M, et al. OpenID Connect Core 1.0 incorporating errata set 1[S/OL]. The OpenID Foundation, 2014.
- [19]SAKIMURA N, BRADLEY J, AGARWAL N. Proof Key for Code Exchange by OAuth public clients[R/OL]. RFC 7636, 2015.
- [20]FETT D, CAMPBELL B, BRADLEY J, et al. OAuth 2.0 Demonstrating Proof-of-Possession (DPoP)[R/OL]. RFC 9449, 2023.
- [21]HARDT D, PARECKI A, LODDERSTEDT T. The OAuth 2.1 authorization framework[S/OL]. IETF Internet-Draft draft-ietf-oauth-v2-1, 2024.
- [22]ROSE S, BORCHERT O, MITCHELL S, et al. Zero trust architecture[S]. NIST Special Publication 800-207, 2020.
- [23]XIE Y, et al. Exploit tool invocation prompt for tool behavior hijacking in LLM-based agentic system[DB/OL]. arXiv:2509.05755, 2025.
- [24]ZHANG X, et al. MemMorph: Tool hijacking in LLM agents via memory poisoning[DB/OL]. arXiv:2605.26154, 2026.
- [25]Visual inception: Compromising long-term planning in agentic recommenders via multimodal memory poisoning[DB/OL]. arXiv:2604.16966, 2026.
- [26]The misattribution gap: When memory poisoning looks like model failure in
-

- agentic AI systems[DB/OL]. arXiv:2605.22842, 2026.
- [27]Anthropic's Mythos escaped its sandbox[EB/OL]. Ship Safe CLI Blog / OWASP Agentic AI Top 10 Mapping, 2026.
- [28]4C framework: Core layer threats in agentic AI[DB/OL]. arXiv:2602.01942, 2026.
- [29]Stop fixating on prompts: Reasoning hijacking and constraint tightening for red-teaming LLM agents[DB/OL]. arXiv:2604.05549, 2026.
- [30]BOOTH H, et al. Accelerating the adoption of software and AI agent identity and authorization[R/OL]. NCCoE Concept Paper, National Institute of Standards and Technology, 2026.
- [31]BIRGISSON A, POLITZ J G, ERLINGSSON Ú, et al. Macaroons: Cookies with contextual caveats for decentralized authorization in the cloud[C]//Proceedings of the Network and Distributed System Security Symposium (NDSS). San Diego: Internet Society, 2014.
- [32]CAO L, MENG L, STEFAN D, et al. Stateful least privilege authorization for the cloud[C]//Proceedings of the 33rd USENIX Security Symposium. Philadelphia: USENIX Association, 2024: 3477-3494.
- [33]CHOPRA V. OAuth is not enough: Authorization challenges for autonomous AI agents[DB/OL]. TechRxiv, 2025. DOI: 10.36227/techrxiv.174952577.74018032.
- [34]SOUTH T, et al. Authenticated delegation and authorized AI agents[DB/OL]. arXiv:2501.09674, 2025.
- [35]SHARMA R K, JIANG L, LIN Z, et al. PAuth: Precise task-scoped authorization for agents[DB/OL]. arXiv:2603.17170, 2026.
- [36]UCHIBEKE U. Before the tool call: Deterministic pre-action authorization for autonomous AI agents[DB/OL]. arXiv:2603.20953, 2026.
- [37]FLEMING C, KUNDU A, KOMPELLA R. Uncertainty-aware, risk-adaptive access control for agentic systems using an LLM-judged TBAC model[DB/OL]. arXiv:2510.11414, 2025.
- [38]PRAKASH S. AIP: Agent identity protocol for verifiable delegation across MCP and A2A[DB/OL]. arXiv:2603.24775, 2026.
-

[39]TALLAM K. Authorization propagation in multi-agent AI systems: Identity governance as infrastructure[DB/OL]. arXiv:2605.05440, 2026.